

● CRITICAL SEVERITY

SQL INJECTION ATTACK

INCIDENT RESPONSE PLAYBOOK

ORGANIZATION	University of Delaware
PREPARED BY	Kavya Sri Reddy
GENERATED	2026-05-28 16:04:22
NIST FUNCTIONS	Detect, Respond, Recover
SLA — CONTAINMENT	6 hours
SLA — RESOLUTION	1 week

INCIDENT DESCRIPTION

An attack where malicious SQL code is inserted into input fields to manipulate backend databases, enabling unauthorized data access, modification, or deletion.

LOG SCAN RESULTS — CRITICAL RISK

FILE SCANNED	sample_sql_injection_from_dataset.txt
LINES SCANNED	1000
IOCS FOUND	186
RISK SCORE	100 / 100
RISK LEVEL	Critical
ATTACK TYPES DETECTED	sql_injection

IOC FINDINGS:

SEV	DESCRIPTION	LINE	CATEGORY
Critical	SQL injection attempt pattern detected in request	22	Web
Critical	SQL UNION-based or boolean injection detected	22	Web
Critical	SQL injection attempt pattern detected in request	28	Web
Critical	SQL UNION-based or boolean injection detected	30	Web
Critical	SQL injection attempt pattern detected in request	34	Web
Critical	SQL UNION-based or boolean injection detected	34	Web
Critical	SQL injection attempt pattern detected in request	36	Web
Critical	SQL UNION-based or boolean injection detected	36	Web
Critical	SQL UNION-based or boolean injection detected	37	Web
Critical	SQL injection attempt pattern detected in request	38	Web

SCAN RECOMMENDATIONS:

■ IMMEDIATE: Critical IOCs detected — activate IR team now

- Block attacking IP at WAF and review web app for SQLi vulnerabilities
- Preserve all logs — do not clear or rotate until IR is complete

MITRE ATT&CK; TACTICS

- Initial Access (TA0001) — Exploit Public-Facing Application (T1190)
- Collection (TA0009)
- Exfiltration (TA0010)

INDICATORS OF COMPROMISE (IOCs)

- SQL keywords in URL parameters (SELECT, UNION, DROP)
- Unusual database error messages in HTTP responses
- Abnormally large database query volumes from single IP
- WAF alerts for SQL injection patterns
- Unexpected outbound data transfers from database server

ESCALATION MATRIX

SEVERITY	ESCALATION PATH
Low	Application Security team
High	CISO + Development Lead + Database Admin
Critical	CISO + Legal + Compliance Officer (if PII exposed)

PHASE: IDENTIFICATION [0-2 hours]

NIST Control: DE.CM-7 — Monitoring for unauthorized connections and software is performed

TOOLS: WAF logs, Web server logs, Database activity monitor, SIEM

RESPONSE STEPS

- 1 Detect via WAF alert, IDS alert, or anomalous database query logs
- 2 Identify the affected web application and vulnerable parameter(s)
- 3 Review web server and database logs for malicious SQL patterns
- 4 Determine attack type: in-band, blind, or out-of-band SQL injection
- 5 Assess what data may have been accessed or exfiltrated
- 6 Identify whether attacker achieved database admin (DBA) privileges

PHASE: CONTAINMENT [2-6 hours]

NIST Control: RS.MI-1 — Incidents are contained

TOOLS: WAF, Firewall, Database admin console

RESPONSE STEPS

- 1 Block attacker IP addresses at WAF and firewall immediately
- 2 Take the vulnerable application offline if data exfiltration is confirmed
- 3 Enable WAF blocking rules for SQL injection patterns
- 4 Disable the vulnerable database account or restrict its permissions
- 5 Preserve all web server, application, and database logs as evidence

PHASE: ERADICATION [6-72 hours]

NIST Control: RS.MI-2 — Incidents are mitigated

TOOLS: OWASP ZAP, Burp Suite, Code review tools, Database auditing

RESPONSE STEPS

- 1 Identify all vulnerable input parameters using DAST scanning tools
- 2 Patch vulnerable code — implement parameterized queries / prepared statements
- 3 Remove any web shells or backdoors planted during the attack
- 4 Audit database for unauthorized stored procedures or triggers
- 5 Review and rotate all database credentials

PHASE: RECOVERY [72 hours - 1 week]

NIST Control: RC.RP-1 — Recovery plan is executed

TOOLS: Database backup system, Application deployment pipeline

RESPONSE STEPS

- 1 Restore database from last known clean backup if data was modified
- 2 Redeploy patched application with parameterized queries enforced
- 3 Enable enhanced database auditing and query logging going forward
- 4 Notify affected users if their personal data was compromised

PHASE: LESSONS LEARNED [Within 1 week]

NIST Control: RC.IM-1 — Recovery plans incorporate lessons learned

TOOLS: SAST tools, DAST tools, Developer training platform

RESPONSE STEPS

- 1 Conduct full code review of all web application input handling
- 2 Implement mandatory input validation and output encoding standards
- 3 Integrate SAST/DAST scanning into CI/CD pipeline
- 4 Schedule developer secure coding training (OWASP Top 10)